

VENDOR RISK PROGRAM: QUARTERLY SUMMARY

Period: Q2 2026 (April 1 – June 30, 2026)

Prepared by: GRC Team

Audience: CISO, VP Engineering, Legal

1. Program Snapshot

Metric	Value
Total vendors tracked	10
Tier 1 / Tier 2 / Tier 3 breakdown	4 / 4 / 2
Assessments completed this quarter	7
Assessments overdue	1

2. Risk Portfolio Summary

Risk Rating	Vendor Count
Critical	2 vendors
High	1 vendor
Medium	3 vendors
Low	4 vendors

Two vendors **PaymentCo** and **Data Backup** Vendor currently sit in the Critical band. Both are Tier 1 vendors with direct payment or continuity exposure, and both have active remediation plans with CISO visibility.

3. Top Risks This Quarter

Vendor	Risk Summary	Status
PaymentCo	MFA not enforced on admin accounts handling cardholder data	Remediation in progress, due in 18 days
Data Backup Vendor	Business continuity test not performed in over 24 months	Remediation plan submitted, CISO briefed
HR Platform SaaS	Encryption at rest not confirmed for stored employee/candidate PII	Vendor attestation requested, response due next week

4. Remediation Progress

Metric	Value
Open remediations	4
Completed this quarter	2
Overdue	1

5. Recommended Actions

- Escalate PaymentCo MFA remediation to CISO if not closed by end of month: Owner: GRC Analyst, Due: July 23, 2026
- Require signed Risk Acceptance Statement from Business Owner for Data Backup Vendor pending full remediation: Owner: VP Engineering, Due: July 15, 2026
- Initiate overdue Tier 2 re-assessment for CDN Provider: Owner: GRC Analyst, Due: July 10, 2026

6. Upcoming Assessments (Next 90 Days)

Vendor	Tier	Due Date
FraudDetection API	1	August 1, 2026
MarketingAnalytics Inc	2	August 15, 2026
CloudHosting Ltd	1	September 1, 2026
Office Supplies Portal	3	September 30, 2026

Bottom line: the vendor risk portfolio is stable quarter over quarter. Two Critical findings are actively tracked with executive visibility, and no new Tier 1 vendors were onboarded without CISO sign-off this quarter.